

Project KIRA

Adversarial Co-Evolution Laboratory for Payment Security

Solution Walkthrough — Technical Report

Mastercard Innovation Challenge 2026 Track: AI Defense Lab for Payment Security

Authoritative run: `run_tiny_s20260827_193f7897_40997ab` **Git commit:** `40997ab` · **Config hash:** `193f789727f6` ·
Seed: `20260827` **Supporting run:** `run_small_s20260827_3a353e9a_052dca8` **Verification:** Gates 0–7 PASS · 152/152
tests green · 22/22 artifacts SHA-256 verified

Document Outline

§	SECTION
1	Executive Summary
2	Problem Statement
3	Threat Model
4	System Architecture — Three Pillars
5	Methodology
6	Experimental Design
7	Results
8	Negative Results and the Generalisation Boundary
9	Independent Research Validation
10	Reproducibility and Provenance
11	Limitations
12	Scalability and Deployment
13	Responsible Disclosure
14	Conclusion and Future Work
A	Appendix — Artifact Index
B	Appendix — Experiment Register
C	Appendix — References

1. Executive Summary

Fraud detection is conventionally evaluated against a static historical distribution. That protocol answers *"does this transaction resemble fraud we have already seen?"* — and an adaptive adversary makes that the wrong question.

Project KIRA is a closed-loop adversarial laboratory built to answer a harder one: **what would an adaptive attacker do against this specific detector, and does hardening against those attacks transfer to attacks the defense has never seen?**

The system generates a stateful synthetic payment world, attacks its own detector under strict query budgets and a declarative mutability mask, classifies every successful evasion into a twelve-class failure taxonomy, retrains a challenger on a prioritised replay buffer, and submits that challenger to a multi-objective promotion gate that can reject it.

What we measured.

- A budgeted attacker defeats the unhardened detector **96.67%** of the time at twenty probes, **with a mean Minimum Evasion Distance of 2.8488**.
- Adversarial hardening drives held-out variant success from **14.55% to 0.00%**, with a generalisation retention of **1.3071** under strict lineage isolation.
- The promotion gate **rejected all four challengers**, because each traded away detection quality below the 0.90 PR-AUC retention threshold. The champion was never replaced.
- Against **withheld attack families**, the attacker achieved **100.00% success**.

Hardening did not transfer.

- On an external benchmark of **284,807 genuine cardholder transactions**, the detector achieved **PR-AUC 0.8640** with a false positive rate of 0.03%.

What this submission argues. Three of those five findings are negative. We report them as first-class results, because a defense laboratory whose only output is good news is not a laboratory. The rejection behaviour of the promotion gate and the measured zero-day boundary are, in our assessment, the two most useful artifacts this project produced.

2. Problem Statement

2.1 The evaluation gap

A standard payment fraud pipeline fits a gradient-boosted classifier on labelled historical fraud and reports precision-recall AUC on a held-out temporal slice. Three structural problems follow.

Attack Success Rate is reported without a query budget. Published adversarial results routinely assume an attacker with unlimited access to the decision function. Such an adversary does not exist. Real attackers are rate-limited, monitored, and pay a cost per probe. A success rate that assumes infinite queries cannot inform a deployment decision, because it does not correspond to any threat the operator actually faces.

Hardening is not distinguished from memorisation. If a defense is hardened on attack variants and evaluated on the same variants — or on sibling variants derived from the same source transactions — the reported improvement measures recall over a fixed set. It says nothing about robustness. Without lineage-aware partitioning applied **before** training, this failure is invisible in the metrics.

Generalisation boundaries are discovered in production. Almost no published fraud work states where its defense stops working. That boundary is then found by an adversary, at cost.

2.2 The question we ask instead

*What would an adaptive attacker do against **this specific detector**, and does hardening against those attacks transfer to attack topologies the defense has never observed?*

Everything in KIRA that does not serve that question was cut.

2.3 Why payments specifically

Payment authorisation has properties that make it an unusually honest testbed for this question. Decisions are made in milliseconds under a hard latency budget. Ground truth arrives late — chargebacks confirm fraud days after the event, so any feature that reads a neighbour's label is unavailable at decision time. The cost matrix is asymmetric and known: a false block carries measurable customer friction, a missed fraud carries the transaction value. And the emergence of autonomous payment agents introduces a threat surface — an agent exceeding its delegated authority — that has no counterpart in conventional fraud modelling.

3. Threat Model

We state the adversary's capabilities and limits explicitly, because an unstated threat model makes every downstream security number uninterpretable.

3.1 What the attacker can do

CAPABILITY	BOUND
Query the decision function	B ∈ {1, 5, 20, 100} probes, enforced and logged per attack
Observe the returned decision	ALLOW / STEP_UP / BLOCK — the decision only
Modify attacker-controllable fields	Only fields permitted by the declarative mutability mask
Adapt between rounds	Yes — Red re-seeds from the previous round's diagnosed weakness profile and attacks the current champion

3.2 What the attacker cannot do

The attacker receives **no calibrated probability, no gradient, and no model internals**. The following fields are immutable and enforced inside the sampler rather than checked after the fact: `txn_id`, `timestamp`, `customer_id`, `balance_before`, `available_credit`, and all hidden evaluation metadata.

Mutations that violate ledger physics are rejected before scoring. In the authoritative run this produced **0 mask violations and 0 physically invalid attacks** — every recorded evasion was legal under the stated threat model.

3.3 Explicitly out of scope

Insider compromise, model extraction, training-data poisoning, and physical point-of-sale tampering are not modelled. We do not claim results against them.

3.4 The five attack families

FAMILY	THREAT SURFACE	MECHANISM
<code>burst_drain</code>	Temporal / velocity	Rapid successive authorisations inside rolling windows
<code>slow_siphon</code>	Temporal / amount	Micro-transactions held beneath amount-based alerting
<code>geo_hop</code>	Spatial	Location shifts within plausible travel-speed tolerance
<code>agent_subversion</code>	Agentic / delegation	Autonomous agent exceeding its authorised mandate
<code>cross_merchant_fanout</code>	Relational / graph	Value distributed across a merchant fan-out topology

The last two are **withheld from the adaptation set** and constitute the zero-day evaluation described in §8.

4. System Architecture — Three Pillars

4.1 Pillar I — IDENTIFY

Detect fraud from strictly causal signal, and diagnose *how* the defense fails.

Causal feature store. Twenty-five canonical features are defined once, in a single specification file, and compiled into two independent implementations: a vectorised batch path for training and a stateful streaming path for serving. Gate 2 asserts the two agree numerically. Causal order is `(timestamp, txn_id)` ascending; a transaction observes only its strict predecessors, never itself and never a successor.

Features that would read a neighbour's fraud label are gated behind a **seven-day chargeback availability lag**, mirroring the production reality that the label does not exist at decision time. This constraint costs measurable performance and is retained because removing it would make every downstream number fictional.

Blue detector. LightGBM (30 estimators, `max_depth=3`) with `scale_pos_weight=171.21` derived from the training split alone. Class imbalance is handled by reweighting, **never by SMOTE** — synthetic minority oversampling distorts posterior probabilities and destroys the calibration on which the cost-sensitive policy depends.

Isotonic calibration is fitted exclusively on an out-of-time validation split, and Expected Calibration Error is computed over ten uniform bins.

Cost-sensitive decision router. Rather than thresholding a probability, the router computes expected financial loss for each of three actions and selects the minimum:

```
E[cost(ALLOW)]   = p · amount · c_fraud
E[cost(STEP_UP)] = c_step_up + (1 - catch_rate) · p · amount · c_fraud
E[cost(BLOCK)]   = (1 - p) · (false_block_fixed + false_block_pct · amount)
```

This is why calibration matters: an uncalibrated score makes every expectation wrong.

Verifiable-Intent engine. Agent-initiated payments carry a `Mandate` — an authorisation object bounding maximum amount, transaction count, permitted merchant category codes, merchant allowlist, validity window, and geographic radius. Intent drift is scored deterministically against that mandate across amount overage, category-scope violation, and authentication anomaly. **No LLM sits in any scoring path.**

Twelve-class failure taxonomy (W1–W12). Every successful evasion is classified — velocity blindness, device-novelty blindness, geographic camouflage, merchant collusion, low-and-slow, graph camouflage, intent drift, coordinated multi-account, synthetic identity, agent swarm, temporal camouflage, open-set anomaly — with hardness, boundary-proximity, novelty, and composite priority scores. This is the step that converts *"the attack succeeded"* into *"the defense has this specific, named blind spot."*

4.2 Pillar II — SIMULATE

Generate adversaries that are constrained, budgeted, and physically valid.

Stateful synthetic world. Four customer archetypes with per-customer behavioural parameters drawn at world creation; merchants with category codes, geography, and risk tiers; a device graph supporting legitimate sharing; agent mandates; and a ledger that rejects physically impossible events. The authoritative run contains **9,348 transactions across 200 customers, 80 merchants and 1,294 devices over 30 days, with 53 frauds (0.567% base rate) and zero Layer-1 physics violations.**

Hard negatives. Travellers, flash sales, and shared family devices — legitimate behaviour that superficially resembles fraud. Without them a detector learns **unusual equals fraudulent**, and the reported false-positive rate is not measuring anything real.

Declarative mutability mask. Enforced inside the mutation sampler. An "evasion" that modified an immutable field would be a bug in the mask, not a discovery.

Budgeted black-box search. Attacks are evaluated against the streaming feature extractor cloned at the source transaction's own timestamp, so the candidate is scored under its true causal history. Transactions already in an `ALLOW` state are excluded from evasion counting — a pre-allowed transaction is not an evasion. Success requires a genuine state transition from a protected decision to `ALLOW`, with non-zero perturbation.

Minimum Evasion Distance. The smallest normalised L1 perturbation over mutable dimensions that flips a protected decision. Reported alongside ASR because MED is invariant to threshold movement. **Where zero evasions occur, MED is mathematically undefined and recorded as `null` — never converted to 0.0.**

Three-world evaluation suite.

- **World A** — adaptation families: `burst_drain`, `slow_siphon`, `geo_hop`
- **World B** — shifted physics: altered customer spending baselines and merchant risk tiers
- **World C** — withheld zero-day families: `agent_subversion`, `cross_merchant_fanout`

Disjointness between the adaptation set and the hidden set is asserted **at runtime**, not by convention. The authoritative run recorded **0 zero-day leakage violations.**

4.3 Pillar III — DEFEND

Harden against diagnosed failures, and refuse to ship a regression.

Prioritised replay buffer. Successful evasions are converted into strictly observable feature rows with zero metadata leakage, sampled by the failure analyser's priority score so that rare, high-value, near-boundary failures are over-represented relative to trivially repeated ones.

Lineage-grouped splitting. Attack variants are grouped by `(source_txn_id, attack_family)` **before** the challenger is trained. Sibling variants derived from the same source transaction cannot appear on both sides of the hardening/held-out boundary. Without this step, a reported generalisation improvement is indistinguishable from leakage.

Weakness-driven adaptive Red. In each round $r \geq 1$, Red generates fresh attack candidates with unique instance identifiers, biases its mutation distribution using `WeaknessProfile(r-1)`, and searches against the **current** champion. This is genuine co-evolution; replaying a fixed attack corpus against successive models would not be.

Multi-objective promotion gate. A challenger is promoted only if it simultaneously satisfies every criterion below. Any failure triggers deterministic rollback.

CRITERION	THRESHOLD
Detection retention	$\text{PR-AUC} \geq 0.90 \times \text{champion}$
Anti-memorisation	$\text{held-out ASR} \leq \text{champion} + 0.05$
Anti-forgetting	$\text{robustness retention} \geq 0.95$
False positive rate	≤ 0.05
Benign approval rate	$\geq 70\%$
Calibration	$\text{ECE} \leq 0.08$
Latency	$\text{P95} \leq 25 \text{ ms}$

5. Methodology

5.1 Contracts and leakage control

Every value crossing a module boundary is a pydantic model. The central `Transaction` record explicitly partitions its fields into an **observable** set the detector may use and a **hidden** evaluation set — `is_fraud`, `attack_family`, `attack_instance_id`, `attack_variant`, `hard_negative`. Gate 0 asserts these two sets are disjoint and jointly cover every field on the model.

This is the single most important defensive measure in the codebase. Leaking one hidden field into the feature set produces a PR-AUC near 1.0 that looks like success and is fraud.

5.2 Temporal discipline

All splits are out-of-time: train precedes validation precedes test, with no shuffling. The calibrator is fitted on validation only. Replay records are drawn strictly from the training split; a forensic audit during development identified and eliminated a path by which test-split transactions could enter the hardening pool, and the invariant `replay_source_ids n test_ids = ∅` is now asserted.

5.3 Determinism

Run identifiers are derived deterministically from configuration hash, seed, and git commit. Artifacts are serialised as canonical JSON with sorted keys. Double execution at an identical seed was verified bit-for-bit identical across all rounds. Every artifact carries a SHA-256 digest in `provenance.json`; the authoritative run verified **22 of 22**.

6. Experimental Design

Eight controlled experiments, each with a stated hypothesis, a named baseline, a named treatment, and a registered conclusion. All share seed `20260827`, configuration hash `193f789727f6`, and world version `world_v1_tiny`.

ID	HYPOTHESIS	BASELINE → TREATMENT
EXP-007-A	Static Red achieves non-zero evasion against the unhardened detector	Zero-knowledge random attacker → constrained mutation search
EXP-007-B	Weakness-informed Red concentrates on vulnerable surfaces	Static Red vs fixed Blue → adaptive Red vs fixed Blue
EXP-007-C	Challenger retraining on prioritised replay reduces attack success	Unhardened champion → hardened challenger
EXP-007-D	Hardening generalises to unseen variants rather than memorising	Unhardened on held-out variants → challenger on held-out variants
EXP-007-E	Defensive features transfer to entirely withheld families	Unhardened zero-day benchmark → hardened champion on World C
EXP-007-F	Evasion success is monotonically non-decreasing in query budget	$B = 1 \rightarrow B \in \{5, 20, 100\}$
EXP-007-G	Hardening alters the Minimum Evasion Distance	Baseline boundary → hardened boundary
EXP-007-H	Verifiable-Intent scoring reduces agent subversion success	Transaction features alone → transaction + mandate intent scoring

A ninth measurement, **LATENCY-002**, benchmarks the scoring endpoint over 200 requests with 10 warm-up iterations.

7. Results

7.1 Detection performance

METRIC	VALUE	SCOPE
PR-AUC	0.9375	small scale — the statistically meaningful figure
PR-AUC	1.0000	tiny scale — small-sample artifact, 5 positives in validation. Not a performance claim
ROC-AUC	1.0000	tiny scale, same caveat
False positive rate	0.0000	0 false blocks across 1,398 legitimate transactions
Expected Calibration Error	0.0000	10-bin, out-of-time validation
Brier score	0.0000	Same partition
Decision distribution	1,398 ALLOW · 0 STEP_UP · 5 BLOCK	—

We draw explicit attention to the tiny-scale PR-AUC of 1.0000. The validation slice contains five positive cases against 1,398 negatives. Near-perfect separability on five positives is a property of the sample, not of the model. **We do not present it as a result.** The small-scale figure of 0.9375 carries the statistical power to be interpretable and is the number we stand behind.

7.2 External reality anchor

Evaluated on the ULB European cardholder benchmark — **284,807 genuine transactions, 492 frauds (0.173% base rate)** — never used for training.

PR-AUC	ROC-AUC	PRECISION	RECALL	FPR	ECE	BRIER
0.8640	0.9820	0.8910	0.7930	0.0003	0.0042	0.0018

The benchmark uses PCA-transformed features and is therefore not directly comparable to KIRA's behavioural feature representation. It is included as a contextual reality anchor: evidence that the modelling approach produces credible numbers on genuine cardholder data, not as a claim of equivalence.

7.3 Adversarial results

Attacker capability against the unhardened detector (EXP-007-A):

QUERY BUDGET	ATTACK SUCCESS RATE
1 probe	33.33%
5 probes	76.67%
20 probes	96.67%
100 probes	96.67%

Mean Minimum Evasion Distance: **2.8488**. Mask violations: **0**. Invalid attacks: **0**.

The saturation between 20 and 100 probes is informative: an attacker who has not succeeded within twenty probes is unlikely to succeed with eighty more. The decision surface has reachable gaps, and they are found quickly.

Effect of hardening:

ROUND	BASELINE HELD-OUT ASR	CHALLENGER HELD-OUT ASR	RETENTION	GATE
1	14.55%	0.00%	1.0000	REJECTED
2	13.64%	0.00%	1.0000	REJECTED
3	15.45%	0.00%	1.3071	REJECTED
4	15.45%	0.00%	1.3071	REJECTED

Diagnosed failure distribution: 120 total failures, distributed evenly across **W1 velocity blindness (33.33%)**, **W5 low-and-slow (33.33%)**, and **W7 intent drift (33.33%)**. Resulting Red reseeding weights concentrated on `slow_siphon` (0.3365), `burst_drain` (0.3254), and `agent_subversion` (0.2817).

Adaptation cost: approximately **4.21 seconds per round**, 30 retraining steps, 128 MB peak — measured, not estimated.

7.4 Latency

P50	P95	P99	MEAN	MIN	MAX
2.287 ms	2.406 ms	2.503 ms	2.300 ms	2.217 ms	2.660 ms

200 measured requests, 10 warm-ups, **0 failures**, total wall time 0.539 s.

Scope statement. This is an in-process ASGI TestClient benchmark covering request parsing, feature extraction, policy routing, and JSON serialisation. It **excludes** internet network hops, WAN latency, and distributed database synchronisation. It is labelled as a loopback benchmark in every location it appears. It is not a production latency SLA and we make no such claim.

8. Negative Results and the Generalisation Boundary

This section exists because a defense laboratory that reports only successes is not measuring anything.

8.1 Finding One — the promotion gate rejected every challenger

Across all four rounds, every challenger reduced held-out attack success to 0.00%. Every challenger was **rejected** with `REJECT_DETECTION_COLLAPSE`. Challenger PR-AUC fell to between **0.7560 and 0.8417** against a champion of 1.0000 and a retention threshold of 0.90.

The champion was never replaced.

We consider this the correct behaviour and a positive property of the system. The challengers were more robust and worse at their primary task. A promotion gate that accepted them would have shipped a detector that blocks more attacks and catches less fraud — a strictly worse product, arrived at through a metric that only looked at robustness.

A defense that ships a regression is worse than a defense that ships nothing. The multi-objective gate is the component that enforces this, and this run is the evidence that it works under real pressure rather than in principle.

The open research question this raises — how to harden without detection collapse at this scale — is stated in §14 rather than papered over.

8.2 Finding Two — zero-day transfer failed completely

Against **World C**, containing the withheld `agent_subversion` and `cross_merchant_fanout` families, the attacker achieved:

METRIC	VALUE
ASR at budget 20	100.00%
Mean Evasion Distance	3.7706
Zero-day leakage violations	0

Hardening against velocity-based adaptation families **does not transfer** to novel multi-merchant fanout or agent credential-drift topologies.

The higher MED (3.7706 against a baseline 2.8488) indicates the hidden-family attacks required larger perturbations to succeed — the defense was not entirely inert — but the success rate is total. This is a genuine, isolated, runtime-asserted measurement of where the defense stops working, and it is the single most operationally useful number this project produced. An operator deploying this system would know precisely which threat surface remains uncovered.

8.3 Finding Three — the Verifiable-Intent ablation was neutral

A controlled two-arm counterfactual (EXP-007-H) compared `WITH_INTENT` against `WITHOUT_INTENT`, the latter excluding `is_agent_initiated` from training and inference and disabling mandate verification. Identical transactions, identical seed, identical temporal partitions, identical query budget.

ARM	PR-AUC	AGENT SUBVERSION ASR	MANDATE REJECTIONS
With intent	1.0000	100.00%	0
Without intent	1.0000	100.00%	0
Δ	0.0000	0.00%	—

The intent engine is functionally correct and deterministically auditable, but at this scale it produced **no measurable evasion reduction** against unadapted agent subversion. We classify the result as **neutral / inconclusive** rather than claiming a benefit the data does not support. The mechanism was originally motivated as the project's headline zero-day story; the measurement did not support that framing, and the framing was changed rather than the measurement.

9. Independent Research Validation

A separate validation programme evaluated the synthetic world against 50,000 real transactions from the Sparkov benchmark (CC0 1.0, SHA-256 `12d553ab...545f0`).

TRACK	RESULT	INTERPRETATION
C2ST discriminator (S-03)	Test AUC 0.7780 (95% CI 0.7641–0.7918). Synthetic self-split sanity: 0.5025	A classifier can distinguish our synthetic data from real. The 0.5025 self-split confirms the test is correctly calibrated and the 0.778 is a genuine signal, not an artifact
TSTR vs TRTR (S-04)	TSTR PR-AUC 0.0271 vs TRTR 0.4060, gap −0.3789	Training on synthetic and testing on real transfers poorly . Stated plainly
L3 behavioural fidelity (S-02)	Interarrival ratio 9.74×, velocity trigger ratio 20.13×, burstiness difference −0.1667	Measured against real-data variability; shared-device motif not comparable — the reference schema has no device telemetry column
Graph causal leakage audit (S-05)	0 violations across 28,044 edges	No temporal or label leakage in the entity graph. PASS

The first two are unfavourable and are reported without mitigation. Our synthetic world is behaviourally distinguishable from real payment data, and models trained on it do not transfer well to real distributions. The correct reading is that KIRA's synthetic world is a **controlled adversarial testbed**, not a substitute for real data — which is exactly why the external reality anchor in §7.2 exists.

10. Reproducibility and Provenance

Deterministic identity. Run identifiers derive from configuration hash, seed, and git commit:
`run_{scale}_s{seed}_{config_hash}_{commit}`. Two runs with identical inputs produce the identical identifier and byte-identical artifacts.

Cryptographic provenance. Every artifact is SHA-256 hashed into `provenance.json` at write time. Runs are marked finalised and refuse silent overwrite. The authoritative run verified **22 of 22 artifacts**.

The gate ladder. Eight gates each assert one invariant, so that a wrong downstream number identifies the layer that broke rather than requiring a search.

GATE	INVARIANT ASSERTED
0	Schemas validate; observable and hidden field sets disjoint and total
1	Zero physics violations; foreign-key integrity
2	Batch $\equiv$ stream; no feature reads after time t
3	Out-of-time split enforced; beats rule baseline; ECE recorded
4	Zero mask violations; query budget logged; MED computed
5	Held-out ASR reported separately; no regression
6	Every number traces to a run_id and reproduces; not a fixture
7	Submission audit

An unimplemented gate reports `PENDING` and exits non-zero. **It never reports `PASS`**. Current status: **Gates 0–7 PASS, 152/152 tests green.**

The claim register. Every claim appearing in this document, the repository, or the application carries a row in `brain/CLAIMS.md` naming its metric, value, experiment identifier, run identifier, artifact path, and status — `VALID`, `VALID WITH CAVEAT`, `VALID (FAILURE FINDING)`, `NOT MEASURED`, or `VALID (NEUTRAL / INCONCLUSIVE)`.

A claim with no run identifier does not appear.

11. Limitations

We state these because a submission that hides them is asking to be caught.

Scale. The authoritative demonstration run is `tiny` — 9,348 transactions, 53 frauds. The validation slice contains five positives, which is why the PR-AUC of 1.0000 is reported as a small-sample artifact rather than a result.

Synthetic-to-real transfer is weak. C2ST AUC 0.7780 and a TSTR/TRTR gap of -0.3789 establish that our synthetic world is distinguishable from real payment data and that models trained on it transfer poorly. The synthetic world is a controlled testbed.

Filter layers L3 and L4 are partially unmeasured. Layer 1 physical validity (0 violations) and Layer 2 correlation distance (0.18) were measured. The L3 behavioural degradation ratios and the L4 in-pipeline C2ST were scoped out of the bounded runtime and are reported as `null`, not as zero.

Latency is a loopback benchmark. In-process ASGI measurement. Not internet latency, not a production SLA.

Single detector family. LightGBM with isotonic calibration. Graph neural networks, transformers, reinforcement learning, diffusion-based generation, generative replay, and knowledge distillation were deliberately cut in favour of simple, causal, explainable components that could be fully verified within the available time. A half-implemented advanced component invites exactly the question a submission cannot answer.

Intent ablation inconclusive. See §8.3.

Zero-day transfer failed. See §8.2.

Not a production system. Not connected to any payment rail, not benchmarked against live cardholder traffic, not an official implementation of Mastercard Verifiable Intent, Agent Pay, AP2, or EMV 3DS. The `Mandate` object is our own prototype mechanism informed by the publicly described problem those frameworks address.

12. Scalability and Deployment

12.1 Architectural separation

The laptop never trains at scale. The serving layer never computes.

Kaggle CPU sessions execute the pipeline and write immutable artifacts. The API reads them and returns typed schemas. Two consequences, both deliberate: the demonstration cannot fail the way live training fails — there is no model to load badly and no run to time out mid-presentation — and the latency figure is a genuine end-to-end HTTP measurement rather than a `predict()` call timed in a notebook.

12.2 Measured throughput

End-to-end `tiny`-scale execution completes in **20.568 seconds** on CPU:

STAGE	SECONDS
World generation	1.629
Physics validation	0.019
Feature extraction	0.046
Temporal splitting	0.001
Blue training	0.042
Co-evolution (4 rounds)	16.829
External anchor	0.000
Total	20.568

12.3 Path to one million events

COMPONENT	BEHAVIOUR AT 1M ROWS	VERDICT
Stateful simulator	5k–50k events/sec in Python → 20–200 s	Fine
polars joins and rolling windows	Comfortable past 1M on a laptop	Fine
LightGBM training	Minutes on CPU at 1M × 25	Fine
Causal feature build	Fine as polars rolling/group-by windows; fatal as a Python row loop	Watch
Graph features	Group-by aggregations required; networkx traversal does not survive	Watch
Attack search	The actual wall. Requires scoring the full candidate population in one vectorised call	Addressed
Replay stream to the UI	Pre-aggregate and downsample	Addressed

12.4 Cost profile

Zero GPU hours. Zero paid APIs. No LLM in any scoring path. The entire system reproduces from a public repository on free-tier CPU compute. This was a design constraint, not an accident: the whole pipeline is stateful simulation, gradient-boosted trees on tabular data, constrained search, and statistics.

13. Responsible Disclosure

All algorithms operate on synthetic data and open-access public benchmarks. No proprietary cardholder records, card numbers, personally identifying information, or live banking credentials were used, accessed, or exposed at any point.

No attacks were executed against live services, production systems, or third parties. The adversarial engine operates exclusively inside a controlled simulation against a detector we trained ourselves.

This is a security research prototype. It is not an attack platform, and it is not deployable against any real payment infrastructure.

Claims we will never make without direct empirical proof: state-of-the-art; production-ready integration; superiority to any production system; EMV 3DS or live payment rail integration; guaranteed privacy; a network latency SLA; or 100% defense against zero-day fraud — the last of which is directly refuted by our own EXP-007-E finding.

14. Conclusion and Future Work

14.1 What we built

A closed-loop adversarial payment-security laboratory in which a budgeted, constrained Red engine attacks a calibrated, cost-sensitive Blue detector; every successful evasion is classified into a twelve-class failure taxonomy; a

challenger is retrained on a prioritised, lineage-isolated replay buffer; and a multi-objective promotion gate decides whether that challenger is fit to ship.

Every number reported traces to a cryptographically hashed artifact produced by a deterministic run.

14.2 What we learned

The three most valuable outputs of this project are negative results.

The promotion gate rejected every challenger, demonstrating that robustness gains at this scale came at a detection cost the system correctly refused to accept. Zero-day transfer to withheld attack families failed completely, giving a precise and honest generalisation boundary. And the Verifiable-Intent mechanism — which we expected to be the project's headline — produced a measured effect of exactly zero, and was reported as such.

A defense laboratory whose measurements only ever confirm its designers' expectations is not measuring anything.

14.3 Future work

Resolve the robustness-detection tension. The central open question this run raises. Candidate directions: larger-scale runs where the challenger has sufficient benign data to retain detection quality; a curriculum that anneals replay weight; or an explicitly Pareto-aware promotion criterion rather than a hard PR-AUC floor.

Close the zero-day gap. The 100% hidden-family ASR is the clearest target in the project. Structural rather than distributional defenses — of which the intent engine is one instance — are the natural candidate, but they must be shown to work before being claimed.

Scale the intent ablation. EXP-007-H was inconclusive at `tiny`. Whether the mechanism provides measurable benefit at scale, against an *adapted* agent-subversion attacker, is unresolved.

Complete filter layers L3 and L4 in-pipeline rather than as a separate research track.

Reduce the synthetic-to-real gap. C2ST 0.7780 and a TSTR gap of -0.3789 quantify how far the synthetic world sits from real payment behaviour. Both are now measured, which makes them optimisable.

Appendix A — Artifact Index

Every artifact emitted by the authoritative run, all SHA-256 verified.

ARTIFACT	CONTENTS
<code>manifest.json</code>	Run id, commit, config hash, seed, scale, stage timings, entity counts
<code>evaluation.json</code>	Fidelity report, per-round results, external anchor, ablations
<code>scoreboard.json</code>	Per-round fifteen-metric scoreboard
<code>coevolution_metrics.json</code>	Per-round and per-family breakdown
<code>promotion_history.json</code>	Every gate decision, metrics evaluated, thresholds, reasons
<code>weakness_profile.json</code>	W1–W12 distribution, reseeding weights, rare patterns
<code>failures.json</code>	Every diagnosed evasion with lineage
<code>experiment_register.json</code>	EXP-007-A through H with hypothesis and conclusion
<code>three_world_evaluation.json</code>	World A/B/C composition and isolation proof
<code>attack_summary.json</code>	Replay record counts and representative samples
<code>intent_ablation.json</code>	EXP-007-H two-arm counterfactual
<code>latency_benchmark.json</code>	LATENCY-002, 200 requests
<code>external_anchor.json</code>	ULB benchmark metrics, citation, comparability limitations
<code>adaptation_cost.json</code>	Per-round compute cost
<code>blue_metrics.json</code> · <code>red_metrics.json</code>	Final-state detector and attacker metrics
<code>policy_metrics.json</code> · <code>calibration.json</code>	Cost matrix parameters, calibration method
<code>feature_schema.json</code>	25 features, causal contracts, label-delay rules
<code>world_summary.json</code>	Entity counts, fraud rate, physics validity
<code>transactions.json</code> · <code>decisions.json</code>	Full replay stream and decisions
<code>sample_transactions.json</code>	50 samples with scores and attributions
<code>evidence_pack.md</code>	Human-readable audit report
<code>provenance.json</code>	SHA-256 digest for every file above

Appendix B — Experiment Register Summary

ID	CONCLUSION
EXP-007-A	Static Red achieves 96.67% ASR at budget 20 with MED 2.8488
EXP-007-B	Adaptive Red identified dominant weakness W1 velocity blindness
EXP-007-C	Challenger hardening executed across four rounds
EXP-007-D	Held-out variant ASR reduced to 0.00%, generalisation retention 1.3071
EXP-007-E	Zero-day transfer on isolated World C: ASR@20 = 100.00%
EXP-007-F	Query budget scaling verified across $B \in \{1, 5, 20, 100\}$
EXP-007-G	MED measured across baseline and hardened boundaries
EXP-007-H	Intent scoring: $\Delta ASR = 0.00\%$ — neutral / inconclusive
LATENCY-002	P50 2.287 ms, P95 2.406 ms, P99 2.503 ms — loopback benchmark

Appendix C — References

1. Dal Pozzolo, A., Caelen, O., Johnson, R. A., Bontempi, G. (2015). *Calibrating Probability with Undersampling for Unbalanced Classification.* IEEE Symposium Series on Computational Intelligence (SSCI/CIDM). DOI: `10.1109/SSCI.2015.33` . — Source of the external reality anchor; 284,807 European cardholder transactions.

1. Sparkov Credit Card Transactions Fraud Detection Dataset
(`kartik2112/fraud-detection`), CC0 1.0 Universal Public Domain. SHA-256 `12d553ab19440c752d2531ee1af44bb64f12cc3d3839f1649f19e81c230545f0` . — Reference distribution for behavioural calibration and independent validation.

1. Ke, G. et al. (2017). *LightGBM: A Highly Efficient Gradient Boosting Decision Tree.* Advances in Neural Information Processing Systems.

1. Mastercard Newsroom (March 2026). *Verifiable Intent* — open, standards-based framework linking identity, instruction, and outcome. — Motivating context for the mandate mechanism. KIRA is not an implementation of it.

1. Mastercard Investor Relations (June 2026). *Agent Pay for Machines.* — Motivating context for the agentic threat surface.

Every figure in this report traces to an artifact under `artifacts/run_tiny_s20260827_193f7897_40997ab/`, verified by SHA-256, produced by a deterministic run at seed `20260827` and git commit `40997ab`. Metrics that were not measured are reported as not measured. Results that were unfavourable are reported as findings.